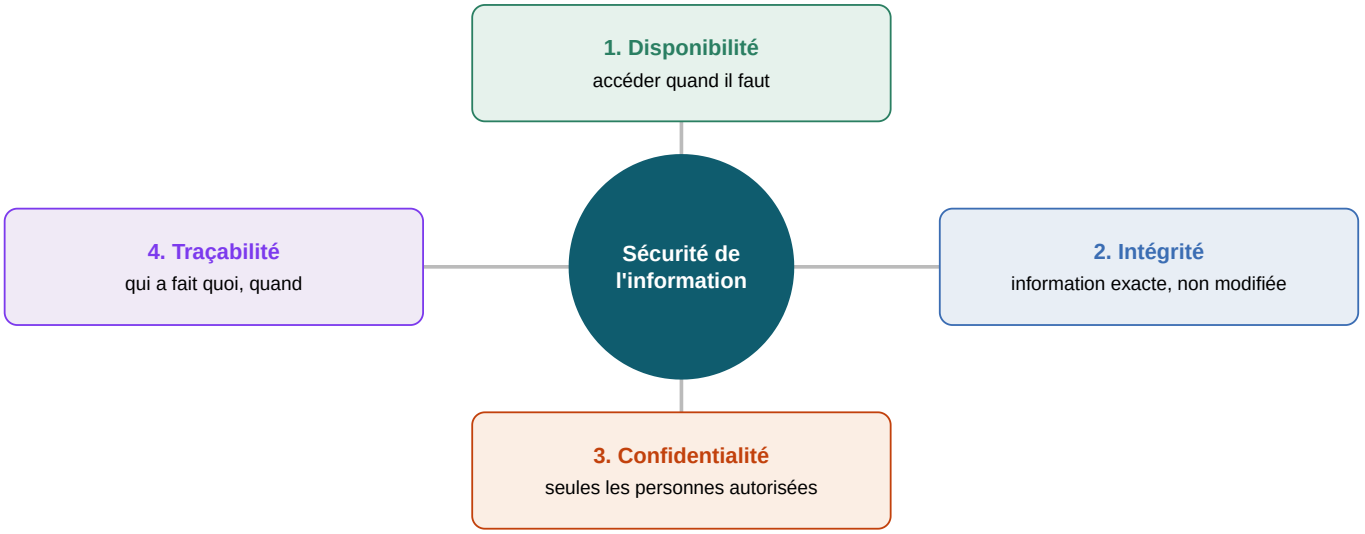
Les schémas du chapitre 21 à savoir refaire

24 schémas qui peuvent tomber à l'écrit (schéma à légender ou à construire) ou être demandés à l'oral E5. Chaque schéma est suivi de ce qu'il faut dire.

1. Les trois objectifs de la sécurité (21.3.1 ; exemple 21.2)



Dire : bilan au mauvais médecin = confidentialité ; texture changée sans raison = intégrité (fausse route) ; messagerie en panne = disponibilité ; identifiant partagé = traçabilité.

2. Menace, vulnérabilité, risque (21.3.1)



Violation de données : destruction, perte, modification, divulgation ou accès non autorisé (RGPD art. 4)

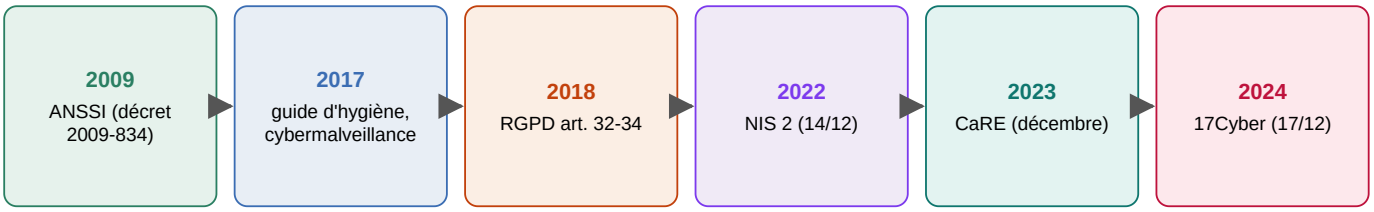
Dire : le système d'information comprend les personnes, les procédures, les outils et les données, y compris la liste papier.

3. Les acteurs de la cybersécurité (21.3.1)

Acteur	Rôle	Date
ANSSI	autorité nationale, guides (hygiène : 42 mesures)	7/7/2009 ; guide 2017
cybermalveillance.gouv.fr	assistance aux victimes, prévention	2017
17Cyber	assistance, mise en relation police ou gendarmerie	17/12/2024
CERT Santé (ANS)	appui et signalement des incidents en santé	—
CNIL	violations de données personnelles	1978
Police, gendarmerie	plainte (72 h pour l'assurance)	LOPMI 2023

Dire : la CNIL reçoit les violations, le CERT Santé les incidents en santé, la police les plaintes. Un établissement prévient aussi l'ARS.

4. Chronologie des textes (21.3.1)



NIS 2 : transposition française pas encore adoptée au 26/10/2026 : vérifier sur Légifrance

> Dire : CaRE ≈ 750 M€ après Dax, Villefranche-sur-Saône (2021) et le CH Sud Francilien (2022).

5. Identité numérique du professionnel (21.3.1 ; exemple 21.3)

Identification	Authentification	Habilitation	Interdit
• dire qui l'on est • identifiant, RPPS	• le prouver • CPS + code, e-CPS • Pro Santé Connect	• ce qu'on a le droit de faire • profil, moindre privilège	• prêter sa CPS • = prêter sa signature • compte partagé

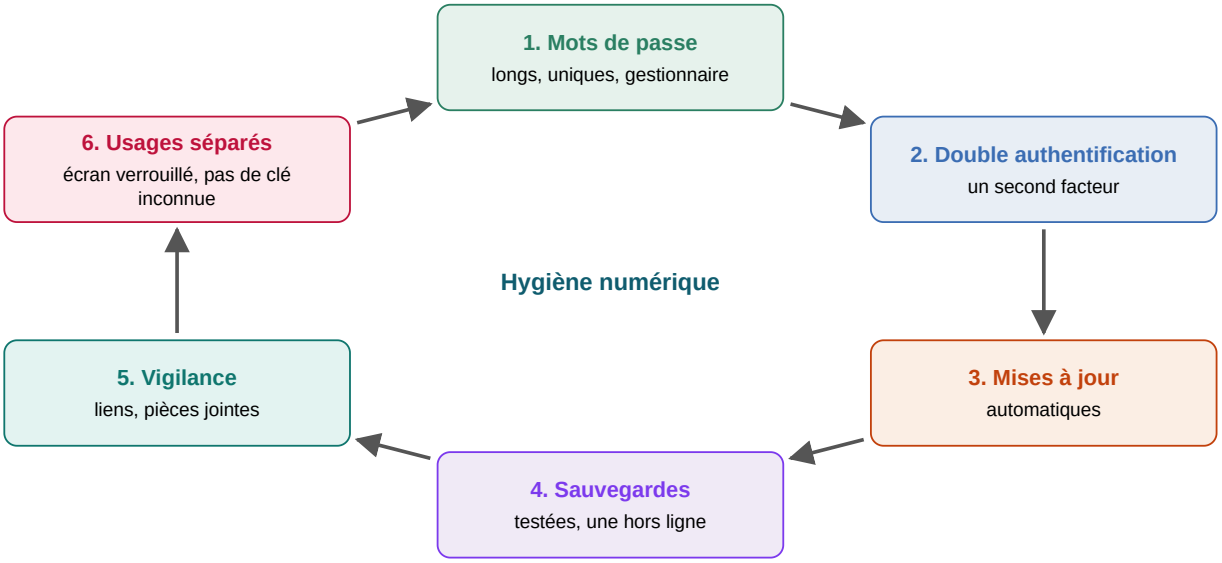
> Dire : la stagiaire reçoit un compte personnel, limité et daté. Le CNED ne cite que la CPS et le lecteur : il existe aussi l'e-CPS et Pro Santé Connect.

6. Quel texte sanctionne quoi ? (21.3.1)

Texte	Ce qu'il protège	Sanction
Code pénal 323-1	le système (accès frauduleux)	3 ans, 100 000 €
Code pénal 226-13	le secret professionnel	1 an, 15 000 €
CSP L. 1110-4	vie privée et secret du patient	renvoie au code pénal
RGPD art. 83	les données personnelles	20 M€ ou 4 % du CA

> Dire : une structure attaquée est victime (323-1) et peut aussi être sanctionnée par la CNIL si elle n'avait pas pris les mesures adaptées (art. 32). CNIL, décembre 2020 : deux médecins libéraux sanctionnés.

7. Les six gestes d'hygiène numérique (21.3.2, figure 21.1 ; schéma à légender)



> Dire : ces six gestes couvrent l'essentiel des attaques courantes ; ils sont gratuits ou peu coûteux.

8. Longueur et temps pour casser un mot de passe (21.3.2 ; exemple 21.11)

Mot de passe	Combinaisons	Temps (10 puissance 10 essais/s)
8 chiffres	10 puissance 8	0,01 s
8 minuscules	≈ 2,1 × 10 puissance 11	≈ 21 s
10 minuscules	≈ 1,41 × 10 puissance 14	≈ 3 h 55
12 minuscules	≈ 9,54 × 10 puissance 16	≈ 110 jours
4 mots (liste de 7 776)	≈ 3,66 × 10 puissance 15	≈ 4,2 jours
6 mots	≈ 2,21 × 10 puissance 23	≈ 700 000 ans

Dire : combinaisons = (caractères possibles) puissance (longueur). Un caractère de plus multiplie par 26 (minuscules). Allonger vaut mieux que compliquer.

9. Recommandations de la CNIL (21.3.2 ; délibération 2022-100 du 21/7/2022)

Mot de passe seul
- 12 caractères
- 4 types (maj., min., chiffres, spéciaux)

Ou bien
- 14 caractères
- 3 types

Ou bien
- phrase de passe
- au moins 7 mots

Moins exigeant si
- blocage des essais
- second facteur

Dire : on ne change plus le mot de passe tous les mois sans raison ; on le change s'il est compromis.

10. Les trois catégories de facteurs (21.3.2 ; exemple 21.12)

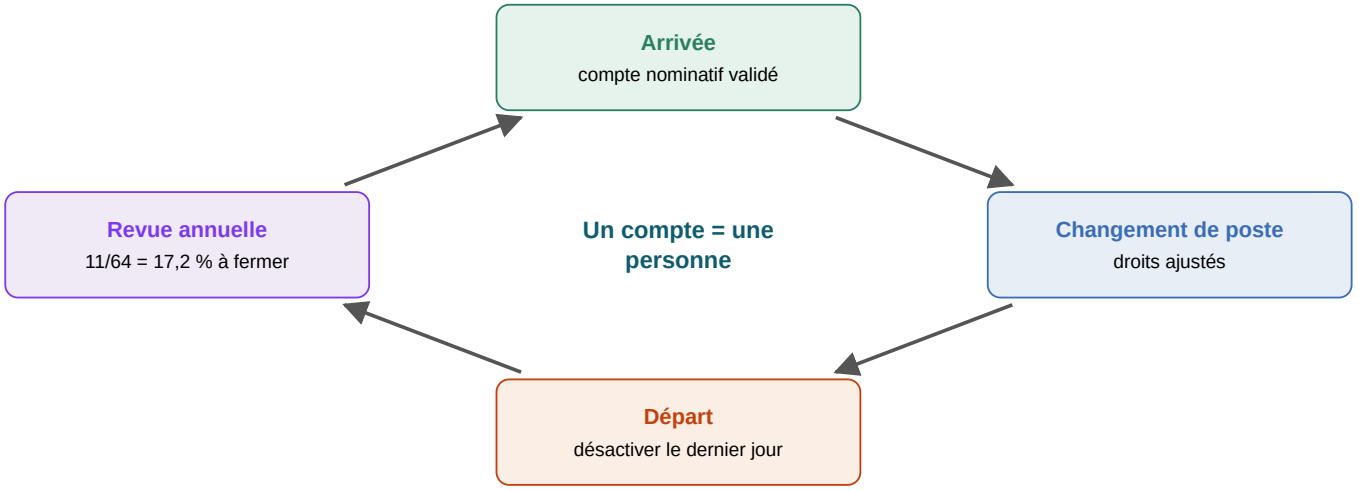
Ce que je sais
- mot de passe, code
- question secrète

Ce que je possède
- CPS, téléphone
- clé de sécurité

Ce que je suis
- empreinte
- visage

Dire : double authentification = deux catégories différentes. Mot de passe + question secrète n'en est pas une. Fatigue des notifications : je ne valide jamais une connexion que je n'ai pas lancée ; je change le mot de passe et je préviens.

11. Gérer les comptes : le cycle de vie (21.3.2 ; exemple 21.24)



Dire : moindre privilège : chacun n'a que les accès nécessaires, le temps de sa mission. Le compte administrateur ne sert qu'aux interventions techniques.

12. Une messagerie sûre (21.3.2 ; exemple 21.18)

1	Le bon outil	messagerie professionnelle ; MSSanté pour la santé
2	Le bon destinataire	vérifier : une erreur d'envoi = une violation
3	Envoi groupé	copie cachée (Cci) ; objet neutre
4	Pièce jointe	archive chiffrée ; mot de passe par un autre canal
5	Partage	lien nominatif avec expiration
6	Absence	ni lieu de vacances ni numéro personnel

Dire : 140 adresses en clair = 140 × 139 = 19 460 affichages ; le titre « Cuisine et diabète » révèle une donnée de santé.

13. La règle 3-2-1 (21.3.2, figure 21.2 ; schéma à légender)

3 copies	2 supports	1 hors ligne	+ un test
• l'original • + 2 sauvegardes	• serveur et disque • ou cloud certifié	• déconnectée ou hors site • non modifiable	• restauration réelle • chronométrée

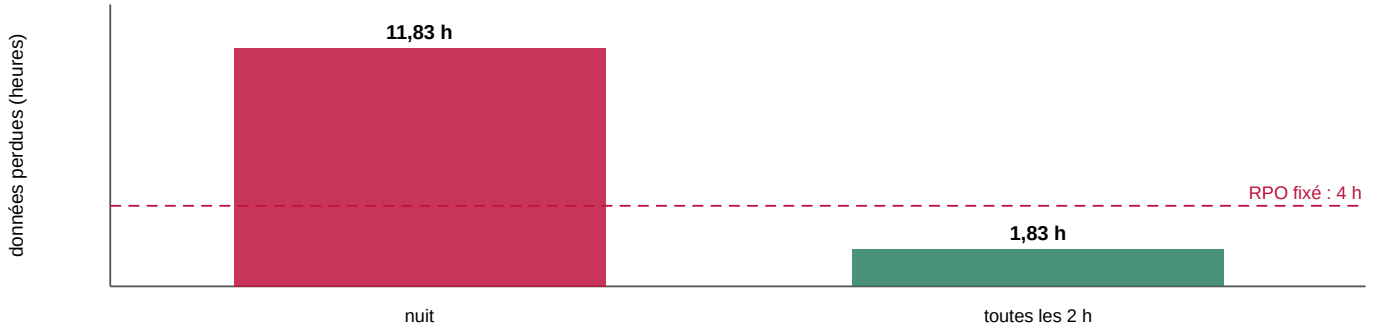
Dire : un disque toujours branché est chiffré avec le reste par un rançongiciel. Conserver assez longtemps (30 jours, infrastructure distincte) : l'intrus reste parfois des semaines.

14. Complète, incrémentale, différentielle (21.3.2 ; exemple 21.26)

Type	Ce qui est copié	Pour restaurer
Complète	tout	la dernière complète
Incrémentale	le changé depuis la dernière sauvegarde	la complète + toutes les incrémentales
Différentielle	le changé depuis la dernière complète	la complète + la dernière différentielle

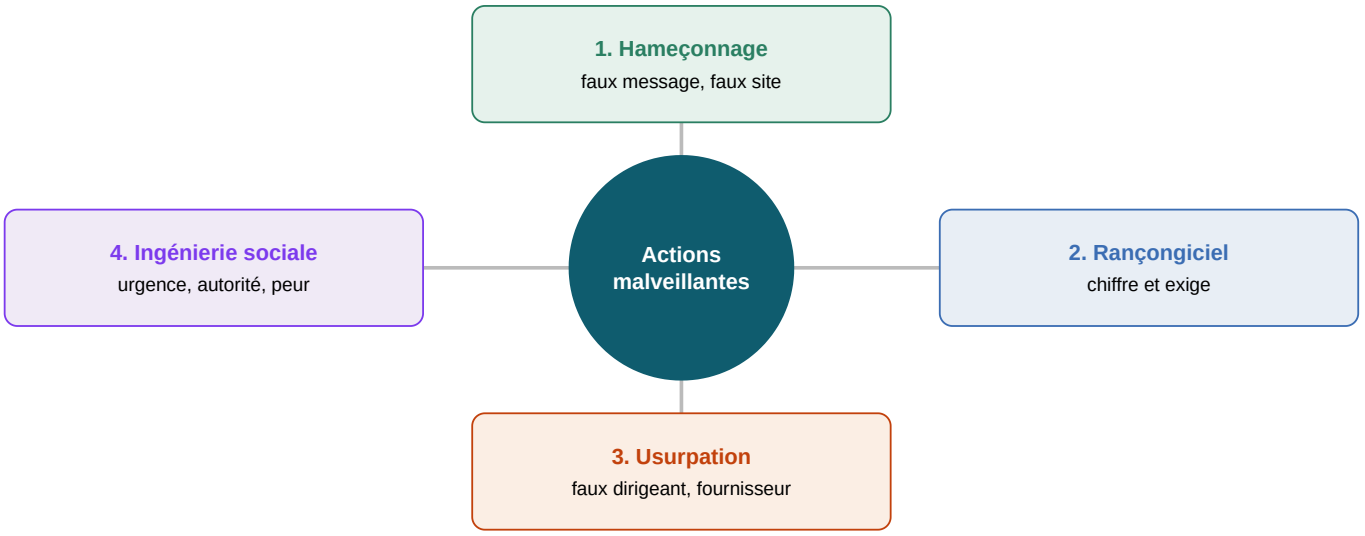
Dire : 40 Go + 1,5 Go par jour : incrémentale 49 Go par semaine, différentielle 71,5 Go. Incrémentale du mardi illisible : restauration fiable jusqu'au lundi soir seulement.

15. Combien peut-on perdre ? (21.3.2 ; exercice 21.28)



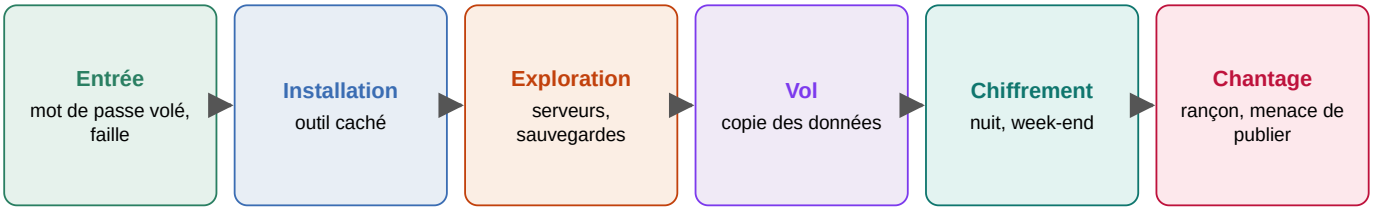
Dire : RPO = perte de données maximale admissible ; RTO = durée maximale d'interruption. On les fixe avec les métiers. Sauvegarde de nuit = 11 h 50 perdues ; toutes les 2 h = 1 h 50.

16. Les quatre grandes menaces (21.3.3, figure 21.3 ; schéma à légender)



Dire : s'y ajoute le faux support technique. Avec l'IA, les messages n'ont plus de fautes : le vrai indice est la demande inhabituelle. SMS suspect → 33700.

17. Une attaque par rançongiciel (21.3.3 ; exemple 21.30)



Double extorsion : chiffrer et menacer de publier ; attaquant entré 23 jours avant > sauvegardes de 15 jours

Dire : même avec de bonnes sauvegardes, le vol des données reste une violation de confidentialité. Ne pas payer.

18. Fraude au virement : trois vérifications (21.3.3 ; cas 9)

1	**Ne pas se fier au seul message**	même s'il vient de la vraie adresse du fournisseur
2	**Rappeler au numéro connu**	celui du contrat, pas celui du message
3	**Double validation**	au-dessus d'un seuil, sans exception

Dire : signes : nouveau RIB, urgence, confidentialité demandée. Cas 9 : 3 960 € pour 96 boîtes = 41,25 € ; rapprocher commande, livraison, facture.

19. Réagir à un incident en six étapes (21.3.4, figure 21.4 ; schéma à légender)

1	**Isoler**	débrancher du réseau sans éteindre
2	**Alerter**	responsable, référent, DPO
3	**Préserver**	ne pas payer, garder les traces, main courante
4	**Signaler**	CNIL 72 h si risque, CERT Santé, cybermalveillance
5	**Restaurer**	sauvegardes saines, mots de passe changés
6	**Tirer les leçons**	plainte, retour d'expérience sans coupable

Dire : la main courante (papier) note l'heure de découverte, qui fixe le départ des 72 h. Éteindre efface des traces utiles.

20. Deux délais de 72 heures (21.3.3-21.3.4 ; exemples 21.37 et 21.45)

CNIL	Plainte	Exemples
• violation présentant un risque • RGPD art. 33 • week-end compris	• pour être indemnisé • LOPMI 2023-22 • L12-10-1 code des assurances	• samedi 8 h → mardi 8 h • vendredi 18 h 50 → lundi 18 h 50 • 30/12 22 h → 2/1 22 h

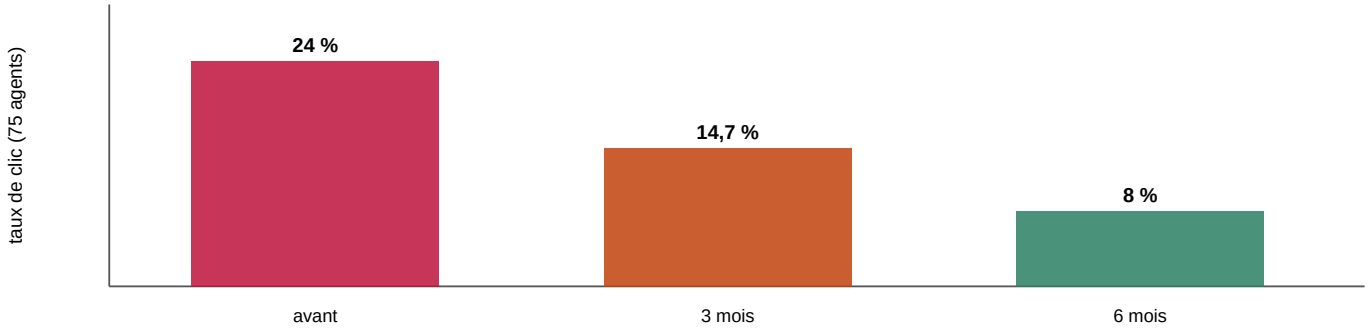
Dire : personnes informées si risque élevé (art. 34) ; registre interne pour toute violation ; CERT Santé et ARS pour un incident grave en établissement.

21. Continuer et reprendre (21.3.4)

PCA	PRA	Informations vitales
• maintenir l'activité • mode dégradé • classeur papier	• rétablir les outils • sauvegardes saines • ordre de reprise	• régimes, textures • allergies, PAI • tournées, priorités

Dire : la liste de secours est aussi un risque : réduite, sous clé, datée, l'ancienne détruite. Un seul porte-parole pour la communication.

22. Mesurer l'effet d'une sensibilisation (21.3.4 ; exemple 21.56)



Dire : signalements 6,7 → 25,3 → 45,3 %. IC à 95 % = p ± 1,96 × √(p(1 − p)/n). 60 agents : 31,7 % [19,9 ; 43,4] → 11,7 % [3,5 ; 19,8] ; si les intervalles se chevauchent, on parle de tendance.

23. Coter les risques (21.4 ; cas 8)

Niveau (V × G)	Classe	Réponse
1 à 3	faible	surveiller
4 à 7	modéré	planifier
8 à 11	élevé	traiter vite
12 à 16	critique	traiter tout de suite

Dire : 9 + 6 + 8 = 23 → 7 après mesures (− 69,6 %). Chiffrement, sauvegarde, liste papier réduisent la gravité ; formation et mises à jour réduisent la vraisemblance. EBIOS RM (2018) : 5 ateliers.

24. Méthode de l'oral E5 (21.6-21.8)



Mesure immédiate et durable ; citer RGPD 2016, ANSSI 2017, CNIL 2022 ; NIS 2 : vérifier

Dire : le jury attend des gestes concrets, des délais justes (72 h week-end compris), la place du diététicien et aucune culpabilisation.